

GOLD Token

Altın destekli dijital token platformu

Projenin basit anlatımı: nedir, nasıl çalışır, nasıl yapılır

Tek cümleyle proje

1 GOLD token = 1 gram %99.99 saflıkta gerçek altın. Dört yetki alanında (Türkiye, İsviçre, BAE, Liechtenstein) lisanslı olarak çalışan, her ay Big Four tarafından denetlenen ve denetim sonucunu blokzincire yazan bir tokenize altın sistemi.

Bu doküman teknik olmayan okuyucu için yazıldı. Detaylı teknik tasarım için [docs/system-design.md](#) dosyasına bakın.

1. Proje Nedir?

GOLD Token, fiziksel altını dijital paraya çeviren bir platformdur. Yatırımcı 100 dolar ile 100 dolar tutarında altın alabilir, ama bunu fiziksel kasada saklamak yerine cüzdanında bir token olarak tutar. Token, gerçek bir altın çubuğa kayıtlıdır — istediği zaman satabilir, bankasına transfer edebilir veya (1 kilogramın üstünde) fiziksel teslim alabilir.

Neden var?

- Erişilebilirlik:** Banka kasasına gitmeden, gram bazında altın alıp satabilirsiniz.
- Şeffaflık:** Her ay bağımsız denetçi kasaları sayar, sonuç herkesin görebileceği şekilde blokzincire yazılır.
- Güven:** Her token gerçek bir altın çubuğa bağlı — kesirli rezerv yok, %100 karlıdır.
- Küresel kullanım:** Türkiye, İsviçre, Dubai ve Avrupa'da yasal — her ülkenin kuralına uyumlu.

Rakiplerden farkı

Özellik	GOLD	PAXG / XAUT
Asgari miktar	1 gram	1 ons (~31 gram)
Yetki alan sayısı	4 (TR/CH/AE/LI)	1
Rafineri	Kendi rafinerisi (Çorum)	Üçüncü taraf
Denetim	Aylık Big Four + Merkle proof	Aylık üçüncü taraf
Çubuk doğrulama	Cüzdandan zincire kadar izlenebilir	Sadece toplam

2. Sistem Nasıl Çalışır?

Kullanıcı bakış açısı

Bir yatırımcının yapacağı işlem altın basit adımda anlatılabilir:

- **Kayıt + KYC:** Kullanıcı uygulamaya giriş yapar, kimliğini doğrular (Türkiye'de TC kimlik, İsviçre'de pasaport, vs.).
- **Para yatırma:** TL, USD, EUR veya AED ile banka transferi yapar.
- **Sipariş:** Mesela 50 gram GOLD almak ister. Sistem güncel altın fiyatından siparişi alır.
- **Tahsis:** Kasadan boş bir altın çubuk bulunur, 50 gram bu kullanıcıya tahsis edilir.
- **Mint (basım):** Blokzincirde 50 GOLD token üretilir ve kullanıcının cüzdanına gönderilir.
- **Kullanım:** Kullanıcı token'ın tutar, borsasına transfer eder, satar veya (1kg+) fiziksel teslim alır.

Sistem bakış açısı (akademi)

Para → Altın → Token zinciri

1. **Fiat geldi:** Banka, ödeme servisi sağlayıcıları üzerinden para platforma ulaşır.
2. **Kasa tahsisi:** Mint/Burn Service müsait altın çubuğa kullanıcının siparişini sağlar.
3. **Çoklu imza onay:** 5 yetkilinin 3'ü mint işlemini onaylar (Hazine, Uyum, Denetçi, Teknik, CIO).
4. **PoR kontrolü:** Son denetim 35 günden eski değilse mint izni verilir. Aksi halde bloklanır.
5. **On-chain mint:** MintController akıllı sözleşmesi token'ın basıp kullanıcının cüzdanına gönderir.
6. **Kayıt:** Tahsisat veritabanına ve event bus'a yazılır; sonraki aylık denetimde Merkle ağacına dahil olur.

3. Sistem Bileşenleri (Lego Parçaları)

Sistemi dört ana katmanda düşünebiliriz. Her katman bağımsız çalışır ama hep birlikte bir altın platformu oluşturur:

A. Akıllı Sözleşmeler (blokzincirde)

- **GoldToken:** ERC-20 token; transfer, bakiye, onay işlemleri.
- **ComplianceRegistry:** Kimin transfer yapabileceğini denetler (KYC, dondurma listesi).
- **MintController:** Yeni token basım; çoklu imza ve PoR kontrolü ile.
- **BurnController:** Token yakım; satım veya fiziksel teslim için.
- **ReserveOracle:** Aylık denetim sonucunun değiştirilemez kaydı.
- **PriceOracle:** Chainlink üzerinden anlık altın fiyatı.
- **Treasury Safe (3/5):** Sözleşme yöneticisi — sadece çoklu imza ile değiştirilebilirlik.

B. Backend Servisleri (sunucularda)

- **Auth:** Giriş, 2FA, oturum yönetimi.
- **KYC/AML:** Kimlik doğrulama, yaptırım listesi taraması.
- **Wallet:** Saklamalı cüzdan (custodial) ve harici cüzdan bağlantısı.
- **Order:** Alım/satım/itfa siparişleri.
- **Mint/Burn:** Kasa tahsisinden zincir üstü mint'e kadar olan süreç.
- **Price Oracle:** Birden fazla kaynaktan altın fiyatı toplama.
- **Proof-of-Reserve:** Aylık Merkle ağacı + IPFS + on-chain yayını.
- **Compliance Engine:** Şüpheli işlem kuralları, Travel Rule.
- **Notification + Reporting:** E-posta/SMS + düzenleyici raporları.

C. Fiziksel Altyapı

Lokasyon	Görev	Yetki Alanı
Çorum — Rafineri	Altın üretimi ve birincil kasa	TR
İstanbul — BIST KMP	Yerel saklama	TR
Zürich — Brink's / Loomis	Avrupa kasası	CH / EU
Dubai — DMCC / Brink's	Körfez kasası	AE

D. Sistemci Uygulamaları

- **Web (Next.js):** Tam fonksiyonlu — onboarding, alım/satım, portföy.
- **iOS + Android:** Mobil odaklı kullanım.
- **Kurumsal API:** Banka ve piyasa yapıcı entegrasyonu (OpenAPI 3.1).
- **verify.gold.example:** Kamuya açık — çubuk/cüzdan sorgulama portalı.

4. Güven Nasıl Sağlanır?

Tokenize altının en zayıf noktası şudur: token'in gerçekten karlı mı olduğunu kim garanti eder? GOLD üç katmanlı bir doğrulama ile bu soruyu cevaplar:

1. Tahsisli rezerv — her token bir çubukla bağlı

Klasik bankalar gibi 'kesirli rezerv' yoktur. Sistem 1.000 token basmıyorsa, kasada o kullanıcılarla tahsis edilmiş 1.000 gram altın vardır — seri numaralarıyla. **bar_allocations** tablosu bu bağlı tutar: hangi çubuğun ne kadar kime tahsisli.

2. Aylık bağımsız denetim

- Her ayın 1'inde Big Four firması (PwC, Deloitte, EY veya KPMG) dört kasayı fiziksel olarak sayar.
- Her çubuğun seri no, ağırlık, saflık, rafineri LBMA kimliği kayda alınır.
- Bu liste Merkle ağacına dönüştürülür ve denetçi EIP-712 ile imzalar.
- Tam rapor IPFS'e yüklenir (kalıcı, değiştirilemez); özet hash blokzincire yazılır.
- Sonuç:** Sistem 35 günden eski denetimle mint yapamaz — kontrat bloklar.

3. Çubuk bazında kullanıcı doğrulaması

Kullanıcı **verify.gold.example** sitesine cüzdan adresini girer. Sistem cevaplar: 'Sizin 50 gramınız, Çorum kasasındaki TR-2026-00428 seri numaralı çubuktan tahsisli.' Kullanıcı bu bilgiyi ReserveOracle ağıyla sözleşmesinde Merkle proof ile bağımsız doğrulayabilir — platforma güvenmek zorunda değil.

5. Nasıl Yapılacak? — Yol Haritası

Proje altı fazda inşa edilir. Her faz öncekinin üstüne bir yetenek ekler; aceleci lansman yerine 'gerçek altın güvenli' öncelikli adım adım büyüme.

Faz 0 — Temel (Ay 0–2)

- Tech lead + 2 smart contract + 2 backend + 1 SRE ile alım
- Ethereum testnet'te GoldToken + ComplianceRegistry + MintController iskeleti
- Yerel geliştirme ortamı (docker-compose) + CI/CD kurulumu
- Güvenlik tehdit modeli atölyesi
- KYC ve kasa tedarikçi POC (Sumsu + Fireblocks)

Faz 1 — MVP Türkiye Arenası (Ay 2–6)

- Türkiye uçtan uca: kayıt → TL yatırma → mint → custodial cüzdan → satış → TL çekme
- Tek kasa: Çorum rafinerisi
- Manuel PoR (aylık tablo + manuel imza)
- İç alpha test (çalışanlar)
- CMB (Sermaye Piyasası Kurulu) ön başvuru

Faz 2 — PoR Otomasyon + İsviçre (Ay 6–10)

- Otomatik PoR: ReserveOracle deploy, Merkle ağacı, IPFS yayını
- Zürih kasa entegrasyonu
- USD/EUR/CHF para girişi-çıkışı
- FINMA SRO başvurusu
- İlk dikkatli güvenlik denetimi (OpenZeppelin)
- Sepolia testnet üzerinde public beta

Faz 3 — Mainnet Lansmanı (Ay 10–14)

- Ethereum mainnet dağıtım + Treasury Safe devri
- İkinci + üçüncü güvenlik denetimi (Trail of Bits, Spearbit)
- 10 milyon dolar başlangıç rezervi → ilk mint
- TR + CH arenaları canlı
- 1–2 borsa listesi + 1 piyasa yapıcı
- verify.gold.example halka açık

Faz 4 — Küresel Ölçek (Ay 14–24)

- Dubai VARA lisansı + BAE arenası
- Liechtenstein / MiCA Avrupa pasaportu
- Avalanche + BNB Chain köprüleri (LayerZero OFT)

- DEX likidite havuzları
- Kurumsal API + banka ortaklıkları
- Merit uyumlu varyant

Faz 5 — Olgunluk (Ay 24+)

- Layer 2 (Base / Arbitrum) genişleme
- Tokenize altın ETF köprüsü
- Altın leasing / yield varyantları
- Kimlik doğrulamalı açık finansal API

6. Teknoloji Seçimleri (Kısaca)

Her seçim 'olgunluk + denetim havuzu + operasyonel kolaylık' ekseninde yapıldı. Hipster teknolojilerden kaçınıldı:

Katman	Seçim	Neden
Akıllı sözleşme dili	Solidity 0.8.24	Audit havuzu en geniş
SC framework	Foundry	Hızlı test, Rust native
SC kütüphanesi	OpenZeppelin + Solady	Denetlenmiş standart
Oracle	Chainlink	En olgun PoR desteği
Köprü (Faz 4)	LayerZero OFT	Merkezi havuz riski yok
Custody	Fireblocks (MPC)	Policy engine + HSM
Backend dili	Go (servisler) + TypeScript (BFF)	Operasyon kolay
Veritabanı	PostgreSQL 16	ACID + zengin özellik
Event bus	NATS JetStream	Hafif, streaming
Web frontend	Next.js 15 + Tailwind + shadcn	SEO + hızlı
Mobile	Swift + Kotlin + KMP shared	Native performans
KYC	Sumsb + Jumio (çift)	Arena başına en iyi
Cloud	AWS primary + GCP DR	Çoklu region
Container	Kubernetes (EKS)	Çoklu cloud taşınabilir

7. Güvenlik Nasıl Korunuyor?

Tokenize altında güvenlik = kontrat güvenliği + anahtar güvenliği + fiziksel güvenlik + uyum. Hepsinin aynı anda çalışması gerekiyor.

Tehdit	Karşı Önlem
Akıllı sözleşme exploit	Çoklu imza + PoR gated + formal verification + 3 bağımsız denetim
Kasa iç tehdidi	4-göz kuralı, CCTV, dual control, çubuk-bağ tag, aylık denetim
Özel anahtar saldırıları	AWS CloudHSM L3 + Fireblocks MPC + cold storage
Kullanıcı phishing	Hardware wallet desteği, EIP-712 domain bağlama
Oracle manipülasyonu	Chainlink + 3+ beslemeden medyan + sapma koruyucu
Reentrancy saldırıları	OpenZeppelin ReentrancyGuard + checks-effects-interactions
KYC by-pass (sybil)	Biyometrik + belge analizi + çift vendor
API DoS	CloudFlare + rate limit + WAF
Regülatör baskısı	Çoklu yetki alanı + İsviçre yedek
Tedarik zinciri (npm/go)	Pinned deps, SBOM, Snyk, iç artifact registry

Operasyonel kurallar

- Sıcak cüzdan:** Toplam arzın en fazla %1'i. Günlük operasyon için.
- Soğuk cüzdan:** Kalan tüm bakiye. Çok imzalı, coğrafi dağıtılmış, geofencing alarmlı.
- Treasury Safe imzacıları:** 5 kişi, 3 farklı lokasyon, 2 farklı jurisdiction. Hepsi Ledger hardware wallet.
- Anahtar rotasyonu:** Yıllık + her güvenlik olayından sonra.
- Bug bounty:** Immunefi üzerinden — kritik 500K USD, yüksek 100K USD.
- Incident response:** RTO 1 saat, RPO 5 dakika.

8. Kim Ne Yapacak? — Bařlangıç Ekibi

Faz 0–1 için önerilen bařlangıç takımı (toplam 13 kiři):

Rol	Adet	Görev
Tech Lead / Chief Architect	1	Genel mimari ve teknik yön
Smart Contract Engineer	2	Solidity + Foundry, kontrat tasarımı ve testleri
Backend Engineer (Go)	3	Mikroservisler, mint/burn, compliance
Frontend Lead (Next.js)	1	Web uygulaması ve verify portalı
Mobile Engineer	2	iOS (Swift) + Android (Kotlin)
SRE / DevOps	1	Kubernetes, CI/CD, gözlemlenebilirlik
Security Engineer	1	Tehdit modeli, audit hazırlığı, key management
QA / Test Engineer	1	E2E testleri, regresyon
Product Manager	1	Sipariş akıřları, KYC akıřları
Compliance Tech Liaison	1	Hukuk + ürün arasındaki köprü

Faz 2'den sonra eklenecek: KYC ops, müşteri destek, business development, data analyst, üç ek arenanın yerel temsilcileri.

9. Hala Açık Olan Sorular

Nisan 2026 toplantısında bazı kararlar kesinleşti, bazıları düzenleyici görüşüne bağlı:

Karara bağlananlar

- **Hassasiyet:** 18 decimals (DeFi uyumu + alt-gram fraksiyonu).
- **Self-custody:** Jurisdiction bazı — TR'de custodial-only, CH/AE/LI'de Enhanced KYC sonrası serbest.
- **Minimum alım:** 1 gram (sipariş bazında). DEX'te fraksiyon serbest.
- **Fiziksel teslim minimumu:** 1 kg (LBMA çubuk bölme maliyeti).
- **Köprü modeli:** Faz 4'te yeniden değerlendirilecek; default LayerZero OFT.

Hala açık

- **Yakım onay:** <100gr otomatik, üstü onay (öneri, henüz onaylanmadı).
- **KVKK veri ikametgâh:** Türk kullanıcı KYC verisi yurt dışı çakabilir mi? Hukuki görüş bekleniyor.
- **Gas ödeme modeli:** Kullanıcı ETH mi öder, meta-tx mi? Önerilen yol: v1 EIP-2612 permit, v2 meta-tx + paymaster.
- **L2 stratejisi:** Day-1 sadece Ethereum mainnet mi, Base/Arbitrum day-1 mi? Önerilen: sadece mainnet, odak.

10. Tek Sayfada Özet

GOLD nedir?

Her token gerçek bir gram altına eşit, dört yetki alanında lisanslı, her ay Big Four denetimli bir tokenize altın platformu.

Nasıl çalışıyor?

Kullanıcı para yatırır → kasadaki çubuğun bir kısmı ona tahsis edilir → çoklu imza ile mint onaylanır → token cüzdana gider. Satarken / fiziksel teslimde tam tersi: token yakılır, çubuk serbest kalır.

Neden farklı?

Çoklu yetki alanı (TR/CH/AE/LI), kendi rafinerisi, gram bazlı minimum, çubuk bazında izlenebilirlik, Merkle proof ile bakiye doğrulama.

Nasıl yapılacak?

6 fazlık, 24+ aylık yol haritası: önce Türkiye MVP, sonra İsviçre + otomatik PoR, sonra mainnet lansman, sonra global ölçek ve olgunluk. Her faz öncekinin üstüne bina yapar.

Ne kadar sürer?

İlk MVP (TR arena, manuel PoR): 6 ay. Mainnet lansman (otomatik PoR + 3 güvenlik denetimi): 14 ay. Global ölçek (4 arena + çoklu zincir): 24 ay.

Daha derin teknik detay için repo içindeki dokümanlara bakın: [docs/system-design.md](#) (972 satır tam mimari), [docs/contracts/README.md](#) (kontrat spesifikasyonu), [docs/backend/README.md](#) (backend servisi spesifikasyonu).